Atividade em Sala: Reconhecimento de Superfície de Exposição com Shodan e Análise de Causa Raiz

Atividade em Sala: Reconhecimento de Superfície de Exposição com Shodan e Análise de Causa Raiz

Disciplina: Segurança da Informação — Engenharia de Software
Duração: 150 minutos (realizada em sala)
Ferramenta: Shodan (conta gratuita é suficiente; os filtros pagos foram deliberadamente evitados)
Formato: Individual
Premissa ética: **Usar apenas os dados de índice passivo do Shodan**. Não é permitido realizar varreduras ativas, conexões, tentativas de login ou exploração de vulnerabilidades em qualquer alvo não autorizado. O objetivo da atividade é "identificar e atribuir causa", não "invadir".

---

1. Objetivos da Atividade

Ao final da atividade, o aluno deverá ser capaz de:

1. Utilizar filtros de busca do Shodan para localizar serviços específicos expostos na internet.
2. Extrair do banner informações sobre tipo de serviço, versão e pistas de configuração.
3. Atribuir o fenômeno de exposição a uma falha específica de configuração ou de design de segurança (categoria OWASP Top 10).
4. Produzir um relatório conciso de análise de superfície de exposição.

---

2. Descrição da Tarefa

Cada grupo escolhe uma **categoria de serviço** e realiza uma busca restrita no Shodan para encontrar **uma instância concreta de serviço acessível pela internet sem qualquer autenticação**, analisando "por que esse serviço está exposto na internet".

Categorias disponíveis (cada grupo escolhe uma, sem repetição):

Categoria	Ponto de partida sugerido	Pista esperada de exposição
Bancos de dados	`port:27017` (MongoDB), `port:6379` (Redis), `port:9200` (Elasticsearch)	Banner sem autenticação / resposta com dados legíveis
Administração remota	`port:3389` (RDP), `port:5900` (VNC)	Tela de login exposta / indicativo de ausência de autenticação
Câmeras / streaming	`port:554` (RTSP), `has_screenshot:true`	Stream de vídeo sem credenciais
Painéis de desenvolvimento / administração	`http.title:"Dashboard"`, `http.title:"phpMyAdmin"`, `http.title:"Jenkins"`	Interface administrativa diretamente acessível
Transferência de arquivos	`port:21` (FTP) + `"Anonymous access granted"`	Indício de login anônimo

Dica de estratégia de busca: use primeiro `count` para confirmar a ordem de grandeza dos resultados e depois restrinja a um país ou organização específica para obter uma amostra analisável. Exemplo: `port:27017 country:BR` (use apenas filtros gratuitos; evite filtros pagos como `vuln:`).

---

3. Estrutura de Análise (a ser preenchida pelos alunos)

Para o serviço exposto encontrado, preencha a tabela de análise a seguir:

Item de análise	Conteúdo exigido
1. Consulta Shodan	Escreva a consulta completa utilizada
2. Identificação do alvo	IP (último octeto pode ser mascarado), porta, organização/ASN
3. Evidência do banner	Copie o trecho-chave do banner no resultado do Shodan (ex.: `"MongoDB Server Information"`, `"Anonymous access granted"`, `"Index of /"`)
4. Identificação do serviço	Nome do produto + versão (se visível no banner)
5. Natureza da exposição	É "ausência de autenticação", "configuração padrão insegura", "interface administrativa indevidamente exposta à internet" ou "protocolo sem design de autenticação"?
6. Atribuição ao OWASP Top 10	Escolha a categoria mais aderente (A01 Falha de Controle de Acesso / A02 Falha de Criptografia / A05 Configuração de Segurança Incorreta / A07 Falha de Identificação e Autenticação) e escreva 2–3 frases de justificativa
7. Hipótese de causa raiz	O que a equipe de operações provavelmente fez (ou deixou de fazer) que resultou nessa exposição? (ex.: bind em `0.0.0.0` sem autenticação, mapeamento da porta padrão do Docker para o host, security group de nuvem aberto para `0.0.0.0/0`)
8. Recomendação de correção de menor custo	1–2 medidas concretas (ex.: habilitar autenticação, alterar endereço de bind, adicionar regra de firewall)

---

4. Roteiro da Aula

Etapa	Tempo	Conteúdo
Introdução O professor demonstra a operação básica do Shodan: busca `port:27017`, exibe um banner de MongoDB e explica que "exposição ≠ vulnerabilidade explorada, mas exposição é pré-condição"
Busca e localização Cada grupo escolhe sua categoria, executa a consulta e encontra uma instância concreta. O professor circula pela sala garantindo que nenhum aluno faça conexões ativas
Análise de banner Os alunos extraem evidências e preenchem os itens 1–5 da tabela de análise
Discussão de atribuição Cada grupo atribui a exposição a uma categoria OWASP, redige a hipótese de causa raiz e a recomendação de correção. O professor conduz a distinção entre "sintoma" (serviço exposto) e "causa raiz" (falha de configuração)
Revisão cruzada entre grupos Dois grupos trocam as tabelas de análise e verificam: a atribuição tem suporte em evidências? A recomendação de correção ataca a causa raiz?
Encerramento O professor sintetiza: o valor do Shodan está em "ver", mas o objetivo da engenharia de segurança é "eliminar a visibilidade desnecessária"

---

5. Casos de Referência (material de apoio do professor, para orientar a lógica de atribuição)

Caso: MongoDB exposto (`port:27017`)

- **Pista no banner**: `MongoDB Server Information` + resposta `"ok" : 1` sem desafio de autenticação.
- **Natureza da exposição**: serviço de banco de dados vinculado à interface pública e sem `authorization` habilitado.
- **Atribuição OWASP**: **A05:2021 Configuração de Segurança Incorreta** (principal), **A01:2021 Falha de Controle de Acesso** (secundária).
- **Causa raiz**: após a instalação, o `bind_ip` padrão é `0.0.0.0` e o administrador não o alterou; ou o Docker foi executado com `-p 27017:27017` sem configuração de autenticação.
- **Correção**: vincular a `127.0.0.1` ou a IP de rede interna; habilitar autenticação no MongoDB; restringir IP de origem no security group.

Caso: stream de câmera RTSP aberto

- **Pista no banner**: `RTSP/1.0 200 OK`, `Content-Type: application/sdp`, SDP obtido via `DESCRIBE` sem autenticação.
- **Natureza da exposição**: serviço de câmera/streaming sem autenticação habilitada, fornecendo stream de vídeo diretamente ao exterior.
- **Atribuição OWASP**: **A07:2021 Falha de Identificação e Autenticação** (principal),

A05:2021 Configuração de Segurança Incorreta (secundária).
- **Causa raiz**: dispositivo com senha padrão de fábrica ou sem senha, ou UPnP abrindo portas automaticamente, e o usuário não alterou a configuração padrão.
- **Correção**: definir senha forte; desabilitar UPnP; colocar o dispositivo na rede interna e acessá-lo via VPN/relay.

---

6. Requisitos de Entrega

Cada grupo entrega **uma tabela de análise** (conforme a Parte 3), sem limite de palavras, mas atendendo a:

- A evidência do banner deve vir do **texto real** da página de resultados do Shodan; não pode ser inventada.
- A atribuição deve ter **suporte em evidências** (ou seja: como as características do banner observado correspondem à definição da categoria).
- A recomendação de correção deve atacar a **causa raiz**, e não apenas dizer "fechar a porta".

---

7. Critérios de Avaliação do Professor

Dimensão	Peso	Pontos de observação
Precisão da busca e localização	20%	A consulta é capaz de reproduzir de forma estável resultados do mesmo tipo
Completude da evidência de banner	25%	Foram extraídos os textos-chave suficientes para sustentar a atribuição
Lógica de atribuição	30%	A escolha da categoria OWASP é razoável e a argumentação é baseada em evidências
Causa raiz e correção	25%	Houve distinção entre sintoma e causa raiz; a recomendação é acionável

---

8. Avisos Importantes (a serem lidos no início da aula)

1. **Apenas leitura, sem tocar**: o Shodan exibe cache de varreduras históricas. **Não** copie o IP do resultado para navegador, terminal ou qualquer ferramenta para conexão, login ou varredura.
2. **Anonimização**: no relatório, substitua o último octeto do IP por `x` (ex.: `189.xxx.xxx.x`).
3. **Não discutir exploração**: esta atividade analisa apenas "por que está exposto"; **não se discute** como explorar o serviço exposto para atacar.
4. O filtro `vuln:` não está disponível na conta gratuita — isso é intencional. O foco da atividade é

inferir a partir de banners e pistas de configuração, e não depender de rótulos de CVE para obter a resposta pronta.